

SECURE ENTERPRISE ARCHITECTURE

Secure Enterprise Security Architecture

Northstar Financial Group (NFG) | Target-State Design

Organization	Northstar Financial Group (fictional)
Architecture Type	Target-State Enterprise Security Architecture
Analyst / Designer	Ryan Bryant
Security Model	Default deny Least privilege Segmented trust Zero Trust-aligned
Scope	Identity, endpoints, network zones, cloud/SaaS, vendor access, monitoring, backup and recovery
Validation	Finance workstation compromise scenario - contained user-level exposure

Portfolio note: This document is a fictional cybersecurity architecture simulation. No real organization or production environment was designed or assessed.

1. Document Purpose and Control

This architecture specification consolidates the security requirements developed across Northstar Financial Group's risk assessment, IAM/RBAC, business continuity/disaster recovery, and third-party vendor risk projects into one target-state enterprise design. The architecture is intentionally product-neutral and emphasizes security outcomes, trust boundaries, recovery capability, and operational accountability.

Field	Value
Document owner	Cybersecurity / Security Architecture
Status	Target-state portfolio design
Review cycle	At least annually and after material infrastructure, vendor, or business changes
Primary stakeholders	Executive leadership, IT, Security, Finance, HR, Compliance, managed service providers
Architecture decision	Adopt deny-unless-explicitly-allowed access between trust zones

1.1 Contents

- 2. Executive Summary
- 3. Design Objectives and Security Principles
- 4. Target-State Architecture
- 5. Security Zone Model
- 6. Trust Boundaries and Inter-Zone Policy
- 7. Internet Edge, Remote Access, and Vendor Access
- 8. Endpoint and Administrative Security
- 9. Identity, Privileged Access, and Zero Trust
- 10. Data Flow and Information Protection
- 11. Security Monitoring and Recovery Integration
- 12. Architecture Validation Scenario
- 13. Implementation Roadmap and Residual Risk
- 14. References and Portfolio Positioning

2. Executive Summary

Northstar's target-state architecture replaces broad internal trust with segmented security zones, identity-aware access, dedicated privileged administration paths, controlled vendor connectivity, centralized security telemetry, and isolated recovery infrastructure. The design assumes that any user, device, vendor identity, or workload can be compromised and therefore limits access to the minimum resources required for the business function.

ARCHITECTURE OUTCOME

A compromise of one Finance workstation should remain a limited user-level incident. The attacker may reach only the resources already authorized to that employee while administrative infrastructure, backups, security systems, vendor paths, unrelated business data, and lateral workstation access remain restricted.

2.1 Business and Security Outcomes

- Reduce lateral movement by separating user, Finance, server, administrative, security, backup, guest, vendor, and cloud trust zones.
- Prevent organizational seniority or network location from creating implicit trust; authorization follows identity, device posture, role, and business need.
- Separate ordinary productivity activity from privileged administration through dedicated privileged identities and workstations.
- Allow remote employees and third-party engineers through different controlled access paths so vendor access can be revoked without disrupting the workforce.
- Protect recovery capability from production compromise through a restricted Backup/Recovery Zone and geographically separate immutable or isolated copies.
- Centralize logs and endpoint telemetry in the Security Zone so cross-zone activity and recovery operations can be investigated and monitored.
- Control sensitive data movement through classification, encryption, DLP, approved transfer channels, time-bound exceptions, and secure deletion.

2.2 Design Basis

The design aligns with NIST Zero Trust Architecture principles, which reject implicit trust based solely on network location or ownership and require explicit authentication and authorization before access to enterprise resources. It also uses the NIST Cybersecurity Framework 2.0 as a risk-management reference and CISA's Zero Trust Maturity Model as an implementation-oriented lens across identity, devices, networks, applications/workloads, and data.

3. Design Objectives and Security Principles

Principle	Architecture Requirement
Default deny	Cross-zone communication is prohibited unless a documented requirement explicitly authorizes source, destination, service, identity, and purpose.
Least privilege	Users, services, administrators, and vendors receive only the access necessary for the current task or role.
No implicit trust	Internal network location, job title, device ownership, or vendor relationship does not automatically grant access.
Administrative separation	Privileged work is performed with separate identities and from dedicated management workstations or jump hosts.
Time-bound exceptions	Temporary permissions include approval, purpose, start time, expiration, and audit logging.
Security visibility	Relevant authentication, network, endpoint, application, vendor, and backup events are centralized and retained for investigation.
Recovery isolation	Production compromise must not automatically provide access to backup or off-site recovery capability.
Secure data lifecycle	Sensitive information is classified, encrypted, transferred through approved channels, retained only as needed, and securely destroyed.
Business continuity	Cloud and third-party services are designed so loss of headquarters or a vendor path does not eliminate Northstar's ability to operate or recover.

3.1 Trust Decision Standard

NORTHSTAR TRUST POLICY

Deny unless explicitly allowed. Every approved trust path should be attributable to a documented business or security requirement, use the narrowest practical scope, and be periodically reviewed for continued need.

4. Target-State Architecture

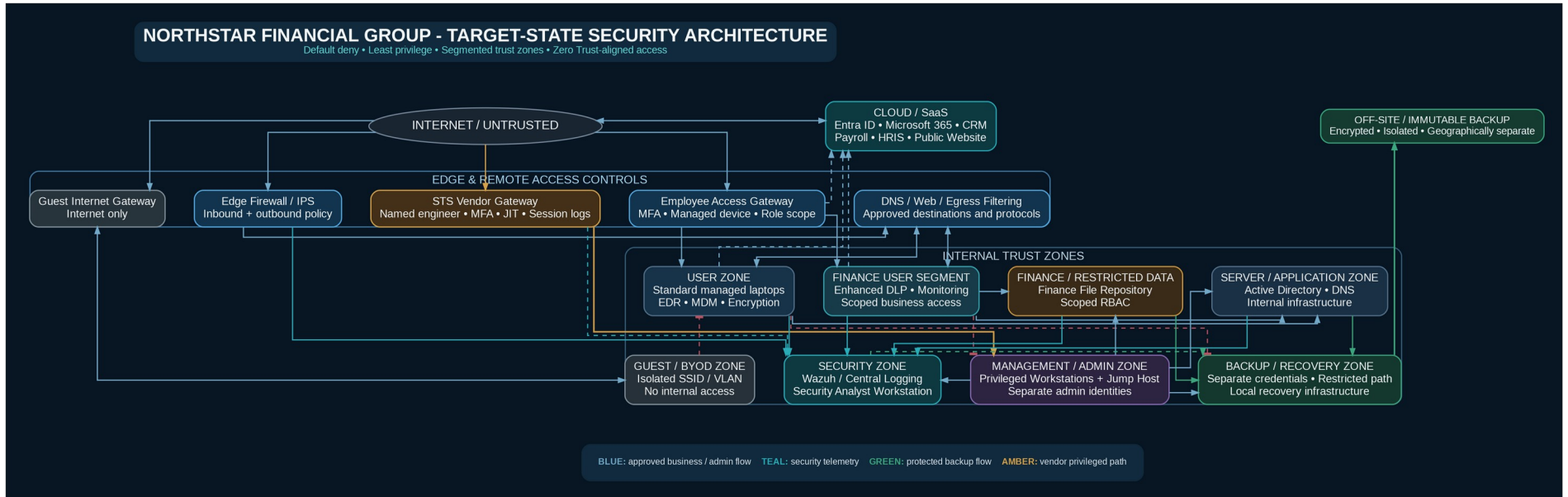


Figure 1. Northstar target-state security architecture. Colored flows distinguish approved business/admin access, security telemetry, protected backup traffic, and vendor privileged access. Red tee-ended flows illustrate default-deny examples.

ARCHITECTURE READING GUIDE

Security zones identify different trust and control requirements; they do not by themselves authorize communication. Access is granted through explicitly approved flows enforced by identity, device, network, and application controls.

5. Security Zone Model

Zone	Primary Purpose	Core Control
Internet / Untrusted	External networks and unknown systems	No implicit trust; inbound and outbound traffic filtered
Cloud / SaaS	Entra ID, Microsoft 365, CRM, Payroll, HRIS, public website	Identity-aware access; no broad unsolicited inbound trust to internal networks
User Zone	Standard managed employee laptops	EDR, MDM, encryption, no local admin by default
Finance User Segment	Finance employee endpoints	Enhanced DLP/monitoring; scoped access to Finance resources
Finance / Restricted Data	Finance File Repository and sensitive financial records	Tight RBAC; no direct guest/user/backup-administration access
Server / Application Zone	Active Directory, DNS, internal infrastructure	Admin only through protected management path; central logging and backup
Management / Admin Zone	Privileged workstations and jump hosts	Separate admin identities, MFA, no routine productivity use
Security Zone	Wazuh/SIEM and Security Analyst workstation	Broad visibility; restricted administration; JIT response authority
Backup / Recovery Zone	Local backup and recovery infrastructure	Separate credentials; no normal user access; restricted management path
Guest / BYOD Zone	Guest wireless and non-corporate devices	Internet-only; hard deny to internal zones
Vendor Access Zone	STS remote administrative entry	Named identities, MFA, JIT, session logging, contract-scoped destinations

5.1 Placement Decisions

- Finance laptops remain endpoints in a Finance user segment rather than being placed inside the restricted server/data zone. A compromised workstation therefore encounters an additional policy boundary before sensitive repositories.
- The public website is cloud-hosted and has no direct trust relationship to Northstar's internal network. Any required integration must use a narrow authenticated API or gateway.
- Wazuh and central security tooling reside in a dedicated Security Zone rather than alongside ordinary application servers.
- Backup infrastructure resides in a dedicated recovery zone and replicates to a geographically separate immutable or isolated recovery copy.

6. Trust Boundaries and Inter-Zone Policy

Traffic Flow	Policy	Authorized Exception / Control
Standard User -> Finance Repository	DENY	Temporary, approved project exception only; time-bound and logged
Finance User -> Finance Repository	DENY by default	Allow only scoped sections required by current assignment/RBAC
Guest Wi-Fi -> Internal Network	HARD DENY	No exception through guest path
User Network -> Backup Zone	HARD DENY	Normal users never manage or browse backup systems
Finance Repository -> Backup Zone	ALLOW with conditions	Dedicated backup service identity; approved protocol; encrypted transport
Internal Systems -> Wazuh	ALLOW telemetry only	Agents/syslog/security telemetry; deny unnecessary interactive access
Wazuh -> Internal Systems	DENY broadly	Allow only agent management, approved integrations, notifications, or scoped active response
Admin Workstation -> Domain Controllers	ALLOW scoped	Named privileged identity from Admin Zone; approved admin protocols
Standard IT Laptop -> DC Admin Services	HARD DENY	Administrative work must originate from protected Admin Zone
STS Vendor Zone -> Domain Controllers	DENY by default	JIT through vendor gateway/jump host for named approved engineer
STS Vendor Zone -> Backup Infrastructure	DENY by default	Contract-scoped JIT access only where operationally required
Cloud SaaS -> Internal Network	DENY unsolicited	Explicit authenticated integrations only; no broad internal reachability

6.1 Exception Governance

- Every exception has a business owner and technical owner.
- Temporary access records the requester, approver, source, destination, purpose, start time, expiration, and associated ticket/incident.
- JIT or automatic expiration is preferred over manual removal.
- Unused firewall rules, vendor permissions, and temporary entitlements are removed during periodic review.

7. Internet Edge, Remote Access, and Vendor Access

7.1 Public Internet and Egress

Northstar restricts both inbound and outbound traffic. Employee web access passes through DNS/web/egress controls, while servers use tighter destination and protocol policies appropriate to their functions. Outbound restriction reduces exposure to command-and-control infrastructure, unauthorized cloud storage, unapproved remote-access tools, high-risk destinations, and data exfiltration paths.

7.2 Employee Remote Access

- Remote employees authenticate through a controlled employee access gateway rather than receiving broad network access by virtue of a VPN connection.
- Access requires MFA, a managed/compliant device, and role-scoped authorization to specific resources.
- Cloud/SaaS access may occur directly through approved identity controls; internal resources remain subject to resource-level authorization.

7.3 STS Vendor Access

Control	Requirement
Identity	Named STS engineer; no generic vendor identity
Authentication	MFA before privileged path is established
Authorization	JIT, task-specific, contract-scoped permissions
Path	Dedicated Vendor Access Gateway -> protected jump host -> approved destination
Monitoring	Session and administrative activity logged; Northstar retains incident evidence rights
Revocation	Vendor path can be disabled independently of employee remote access
Emergency coverage	Named alternate engineer or formally activated emergency access; no unmanaged shared account

8. Endpoint and Administrative Security

System Type	Mandatory Control Profile
Standard employee laptop	Full-disk encryption; MDM; EDR/approved anti-malware; automated patching; no local admin by default; device health checks; removable-media restrictions; DNS/web filtering; remote wipe; scheduled compliance scans
Finance employee laptop	Standard baseline plus enhanced DLP, tighter removable-media controls, restricted Finance application access, and enhanced monitoring of bulk data movement
Privileged administrator workstation	Dedicated admin device; separate admin identity; MFA; application allowlisting; no routine email/social/web browsing; enhanced logging; admin-zone-only management paths; removable-media restrictions
Security analyst workstation	Approved security tools and broad read/investigative visibility; no universal standing administration; incident-response actions granted through SOP-defined scoped/JIT authority
Backup server / recovery systems	Restricted physical and logical access; separate credentials; MFA for human admins; no normal user access; restricted management path; encrypted data; off-site/immutable copy; centralized logging; restoration testing

ADMINISTRATIVE SEPARATION

The same endpoint used for routine email and web browsing should not also be the workstation used to administer domain controllers, backup infrastructure, or other high-impact systems.

9. Identity, Privileged Access, and Zero Trust

The architecture uses identity as a primary policy input rather than relying only on network location. Network segmentation remains important for blast-radius reduction, but authorization is also determined by who or what is requesting access, the device state, the resource being requested, and the current business context.

Identity Type	Target-State Rule
Standard workforce identity	Normal business access only; MFA and managed device requirements for sensitive/remote resources
Privileged administrator identity	Separate from standard account; used only from privileged workstation/jump host; no ordinary productivity use
Security analyst identity	Broad investigative visibility; containment/admin rights activated only when SOP criteria are met
Service identity	Noninteractive; narrowly scoped; managed/rotated credentials; no Domain Admin for convenience
Executive identity	Business authority does not create technical administration; MFA mandatory
Auditor identity	Scoped read-only evidence access; cannot silently alter the records being audited
Vendor identity	Named engineer; MFA; JIT; session logging; destination/service restrictions

9.1 Zero Trust Alignment

Zero Trust Principle	Northstar Implementation
No implicit trust	Network location and device ownership alone never authorize access.
Explicit verification	MFA, device compliance, identity, and resource authorization are evaluated before access.
Least privilege	Standing access is minimized; temporary and privileged access is scoped and time-bound.
Assume compromise	Zones prevent a compromised endpoint or vendor identity from reaching unrelated resources.
Continuous visibility	Identity, endpoint, network, vendor, and system telemetry is centralized for investigation.
Resource protection	Policies focus on the resource and required business flow, not simply whether traffic is inside the LAN.

10. Data Flow and Information Protection

Data Flow	Decision	Control Conditions
Finance employee -> customer financial spreadsheet	DENY ordinary email	Use approved secure portal/file transfer when business-required; verify recipient; log transmission; physical delivery with signature may be an alternative.
HR -> Payroll SaaS	ALLOW with conditions	Approved encrypted integration; authenticated service/API identity; minimum necessary fields; audit/reconciliation logging; alert on failed transfers.
CRM -> local laptop export	DENY by default	Exception requires approved managed endpoint, encryption, DLP, specific dataset, business justification, TTL, and secure deletion.
Finance Repository -> Backup Zone	ALLOW with conditions	Dedicated service identity; encrypted transport; approved source/destination/protocol; users do not gain backup-zone access.
STS engineer troubleshooting download	ALLOW with conditions	Approved support case; named engineer; managed encrypted endpoint/workspace; minimum necessary data; logging; contractual TTL; verified deletion.

10.1 Information Protection Rules

- Sensitive data is classified and access is tied to business role and current assignment.
- Encryption in transit does not replace encryption at rest on endpoints, temporary workspaces, or backup media.
- DLP and egress controls restrict unapproved copying, external sharing, removable media, and cloud destinations.
- Temporary troubleshooting or project access does not create permanent data rights; access and copies expire or are securely deleted.
- Data handling events that materially affect sensitive information are logged where practical for accountability and investigation.

11. Security Monitoring and Recovery Integration

11.1 Security Zone

Wazuh and central logging receive approved telemetry from endpoints, servers, identity systems, the firewall/VPN, Finance services, vendor access, and other relevant sources. The design permits telemetry collection without giving ordinary systems interactive access to the security platform. Wazuh outbound access is limited to functions such as agent management, approved integrations, notifications, and scoped active-response workflows.

11.2 Backup and Recovery Zone

Recovery Control	Target-State Requirement
Production-to-backup flow	Only approved systems/services communicate with backup infrastructure through dedicated backup identities and required protocols.
Administrative access	Restricted to approved privileged identities through the Admin Zone; no normal user path.
Credential separation	Backup administration does not rely on ordinary shared domain credentials.
Resilience	Local recovery copy plus geographically separate immutable/isolated copy to avoid a shared failure domain.
Validation	Scheduled restoration tests demonstrate that recovery data is usable; backup success messages alone are insufficient.
Monitoring	Administrative, backup, restore, and configuration events are logged to support investigation and accountability.
RECOVERY DESIGN RULE	
Production compromise must not automatically provide access to recovery infrastructure, and failure of one physical location, vendor, or credential set must not eliminate every recovery option.	

12. Architecture Validation Scenario

12.1 Scenario

A Finance employee receives a phishing email and unknowingly executes malicious software on a managed Finance laptop. The attacker controls the workstation and has the employee's normal credentials.

Resource	Expected Result	Rationale
Internet	LIMITED / CONTROLLED	Outbound access remains subject to DNS, web, protocol, and egress filtering.
Employee's authorized Finance files	POTENTIALLY ACCESSIBLE	Compromise inherits the victim's legitimate permissions; DLP/EDR must detect and contain misuse.
Other Finance repository areas	DENIED	RBAC and scoped repository permissions prevent broader access.
Domain Controller administrative services	DENIED	Admin protocols available only from protected Admin Zone using privileged identity.
Wazuh / Security administration	DENIED	Endpoint may send telemetry but cannot administer the Security Zone.
Backup / Recovery Zone	DENIED	No user-network management path; separate backup identities and zone controls.
STS Vendor Zone	DENIED	Vendor path is isolated and separately authenticated.
Payroll / HRIS	DENIED unless specifically entitled	Compromise receives no rights beyond the user's legitimate role.
Other employee devices	DENIED by default	Peer-to-peer workstation communication is blocked unless explicitly required.
Management / Admin Zone	DENIED	No direct trust from Finance user segment to privileged management resources.

VALIDATION RESULT - PASS WITH RESIDUAL USER-LEVEL EXPOSURE

The architecture limits the blast radius of a single compromised Finance endpoint. The primary residual exposure is data and cloud resources already authorized to that employee; endpoint detection, DLP, session revocation, and incident-response processes remain necessary to detect and contain the compromised identity.

13. Implementation Roadmap and Residual Risk

Window	Priority	Key Actions
0-30 days	Governance and access foundations	Approve default-deny zone policy; inventory required flows; isolate guest Wi-Fi; document privileged identities; define vendor access owners; confirm log sources and backup credentials.
31-60 days	Segment and control	Implement VLAN/firewall zone boundaries; employee and vendor access gateways; MFA/device compliance; privileged jump host; standard IT-to-admin hard deny; begin Finance DLP and outbound filtering.
61-90 days	Protect data and recovery	Complete restricted Backup Zone; establish geographically separate immutable/isolated copy; formalize secure SaaS integrations; enforce endpoint baselines; test representative restore and access-revocation scenarios.
90-180 days	Mature and validate	Automate JIT/PAM where feasible; refine microsegmentation; tune DLP/egress policy; conduct architecture tabletop/technical validation; review exceptions and measure policy effectiveness.

13.1 Residual Risks and Design Assumptions

- Authorized user access remains usable by an attacker who successfully compromises that identity until detection/containment occurs.
- Cloud/SaaS availability, identity integration behavior, and provider-specific controls must be validated against actual vendor capabilities and contracts.
- Segmentation can reduce blast radius but does not replace secure endpoint configuration, patching, vulnerability management, or application security.
- High availability, bandwidth sizing, licensing, cost, and exact firewall/port requirements require engineering validation before production implementation.
- Product-specific architecture was intentionally avoided; this design represents security requirements and trust relationships, not a procurement bill of materials.

13.2 Success Metrics

Metric	Target
Inter-zone rule coverage	100% of approved cross-zone flows mapped to documented business/security owner and purpose
Privileged path compliance	100% of Domain Controller/backup administration originates from approved Admin/Vendor path
Guest isolation	0 routable guest paths to internal Northstar zones

Metric	Target
Backup isolation	0 normal-user management paths to Backup Zone; restore tests completed on schedule
Telemetry coverage	Critical zones send expected logs/agent data to Wazuh with defined health/freshness monitoring
Temporary access	Exceptions have start/end dates and expire without manual intervention where technically supported

14. References and Portfolio Positioning

14.1 References

- National Institute of Standards and Technology. (2020). Zero Trust Architecture (NIST Special Publication 800-207). <https://doi.org/10.6028/NIST.SP.800-207>
- Cybersecurity and Infrastructure Security Agency. (2023). Zero Trust Maturity Model, Version 2.0. <https://www.cisa.gov/resources-tools/resources/zero-trust-maturity-model>
- National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). <https://doi.org/10.6028/NIST.CSWP.29>

14.2 Employer-Facing Project Summary

PORTFOLIO SUMMARY

Designed a target-state enterprise security architecture for a fictional 75-person financial organization, integrating segmented trust zones, default-deny inter-zone controls, identity-aware remote access, separate privileged administration, vendor JIT access, centralized Wazuh telemetry, DLP-aware data flows, and isolated backup/recovery infrastructure. Validated the design against a compromised Finance workstation scenario to demonstrate blast-radius reduction.

14.3 Resume Bullet

Designed and documented a Zero Trust-aligned target-state security architecture spanning 11 trust zones, default-deny network flows, privileged/admin separation, vendor JIT access, centralized logging, data protection, and isolated recovery; validated the design against a compromised Finance endpoint scenario.

14.4 Interview Talking Points

- Why a Finance workstation belongs in a user segment rather than inside the restricted Finance server zone.
- How default-deny segmentation differs from simply placing systems on different VLANs.
- Why Wazuh needs telemetry from systems without granting those systems interactive access to the SIEM.
- How separate employee and vendor remote-access paths reduce operational dependency and improve revocation capability.
- Why a privileged administrator should use a dedicated workstation and identity instead of an everyday email/browser endpoint.
- How the phishing validation scenario demonstrates residual user-level exposure while preventing enterprise-wide compromise.

Final Architecture Determination: APPROVE AS TARGET STATE - subject to product-specific engineering, performance, budget, high-availability, and implementation validation.